

Vulnerability Scanning Enumeration Using Nmap



By Imteyaz Ali

Kali Linux | Metasploitable2 Lab

Target IP: 192.168.248.130

Date: April 29, 2025

I practiced a complete Nmap-based enumeration on a vulnerable virtual machine, including:

- Scanning all **TCP ports** to detect hidden services.
- Enumerating **service versions** and matching against known CVEs.
- Tracing routes and identifying possible network-level misconfigurations.
- Preparing a detailed document with command-level explanations and vulnerabilities discovered.

1 Introduction

This document summarizes the most widely used **Nmap** commands for reconnaissance and vulnerability assessment. Each command is explained with its syntax, use case, and output expectation.

2 Command Explanations

2.1 1. TCP SYN Scan (Stealth Scan)

```
nmap -sS <target>
```

Use Case: Stealthy port scan using SYN packets. It's faster and less detectable by firewalls or logging tools. **Details:**

- Sends only the SYN packet to initiate a handshake.
- If a SYN-ACK is received, the port is open.
- No full connection is made.

2.2 2. Service Version Detection

```
nmap -sV <target>
```

Use Case: Identifies the version of services running on open ports. **Details:**

- Helps in vulnerability matching.
- Useful in mapping software stack and exposed applications.

2.3 3. Aggressive Scan (Full Recon)

```
nmap -A <target>
```

Use Case: Enables OS detection, script scanning, version detection, and traceroute. **Details:**

- Very informative but also noisy.
- May trigger intrusion detection systems.

2.4 4. Operating System Detection

```
nmap -O <target>
```

Use Case: Attempts to guess the OS of the target using TCP/IP stack fingerprinting. **Output:** Linux, Windows, BSD, etc., along with confidence level.

2.5 5. Full Port Scan (All 65535 Ports)

```
nmap -p- <target>
```

Use Case: Scans all possible TCP ports. **Why:** Many services run on non-standard ports.

2.6 6. UDP Port Scan

```
nmap -sU <target>
```

Use Case: Detect open UDP services (e.g., DNS, SNMP). **Note:** Slower than TCP scanning. Combine with TCP scans for full coverage.

2.7 7. Default Script Scan

```
nmap -sC <target>
```

Use Case: Runs Nmap's default NSE (Nmap Scripting Engine) scripts. **Covers:** Auth checks, banner grabs, SSL info, etc.

2.8 8. Aggressive + Verbose Scan

```
nmap -T4 -A -v <target>
```

Use Case: Time-optimized and verbose aggressive scan. **T4:** Speeds up scan by sending faster probes.

2.9 9. Skip Host Discovery

```
nmap -Pn <target>
```

Use Case: Scans the host even if ICMP ping fails. **Why:** Useful when hosts are behind firewalls or ping is blocked.

2.10 10. Fast Scan (Top 100 Ports)

```
nmap -F <target>
```

Use Case: Quick scan of most common ports. **Speed vs Coverage Trade-off.**

2.11 11. TCP Connect Scan

```
nmap -sT <target>
```

Use Case: Full TCP connection. Used when SYN scan isn't permitted. **Less stealthy** but more compatible.

2.12 12. Null Scan

```
nmap -sN <target>
```

Use Case: Sends packets with no flags set. **Used for:** Firewall evasion and OS detection tricks.

2.13 13. Xmas Scan

```
nmap -sX <target>
```

Use Case: Sends packets with FIN, URG, and PUSH set. **Note:** Some systems treat this as invalid and drop the request — behavior used for detection.

2.14 14. FIN Scan

```
nmap -sF <target>
```

Use Case: Similar to NULL and Xmas scan — firewall evasion and OS fingerprinting.

2.15 15. Version Scan with All Versions

```
nmap -p <port-range> -sV --version-all <target>
```

Use Case: Try all version detection probes aggressively. **Benefit:** Maximum detail on service versions.

2.16 16. Full Scan with TCP and UDP

```
nmap -sS -sU -T4 -A -v <target>
```

Use Case: Perform a detailed scan combining both TCP and UDP checks. **Best For:** Deep reconnaissance phase.

2.17 17. Scan All Ports with Aggressive Flags

```
nmap -p 1-65535 -T4 -A -v <target>
```

Use Case: Check every port with aggressive detection. **High coverage but slow and loud.**

Nmap Scan Results with Vulnerabilities

Port	Service	Version	Vulnerabilities
21/tcp	FTP	vsftpd 2.3.4	Backdoor vulnerability (CVE-2011-2523) allows unauthenticated remote shell access.
22/tcp	SSH	OpenSSH 4.7p1	Multiple vulnerabilities including CVE-2008-4109 (DoS), weak configuration options.
23/tcp	Telnet	Linux telnetd	Transmits data in plaintext; susceptible to credential sniffing and MitM attacks.
25/tcp	SMTP	Postfix smtpd	Version not fully known—potentially vulnerable to open relay and STARTTLS downgrade if improperly configured.
53/tcp	DNS	ISC BIND 9.4.2	Multiple DoS vulnerabilities (e.g., CVE-2008-0122, CVE-2009-0025).
80/tcp	HTTP	Apache 2.2.8	CVE-2007-6388, CVE-2008-0455—includes DoS and cross-site scripting (XSS) issues.
111/tcp	RPCBind	v2	RPC-based attacks, vulnerable to information disclosure, CVE-1999-0002 (old RPC versions).
139/tcp	NetBIOS	Samba smbd 3.X - 4.X	Vulnerable to SMB enumeration, CVE-2007-2447 (remote code execution).
445/tcp	SMB	Samba smbd 3.0.20-Debian	CVE-2007-2447 and other RCE exploits; default null session allows unauthenticated info leaks.
512/tcp	Rexec	netkit-rsh rexecd	Transmits credentials in plaintext; susceptible to remote command execution and trust abuse.
513/tcp	Rlogin	OpenBSD/Solaris rlogind	Plaintext auth, vulnerable to credential reuse and session hijacking.
514/tcp	TCPWrapped	Unknown	Depends on actual service; commonly used by ‘syslogd’—check configs for log injection flaws.
1099/tcp	Java RMI	GNU Classpath gr-miregistry	CVE-2013-1537, CVE-2011-3556—RCE via serialized object injection.
1524/tcp	BindShell	Metasploitable root shell	Hardcoded shell—intentionally vulnerable; unauthenticated remote root access.
2049/tcp	NFS	v2-v4	CVE-1999-0174—allows unauthorized access to shared directories via misconfigured exports.
2121/tcp	FTP	ProFTPD 1.3.1	CVE-2009-3639—remote attackers can exploit via crafted FTP commands.

3306/tcp	MySQL	5.0.51a-3ubuntu5	CVE-2008-2079, CVE-2008-0226—auth bypass, DoS, info disclosure.
5432/tcp	PostgreSQL	8.3.0 - 8.3.7	CVE-2007-6600, CVE-2008-2141—SQL injection and DoS vulnerabilities.
5900/tcp	VNC	Protocol 3.3	No encryption by default—vulnerable to sniffing and bruteforce (CVE-2019-15681).
6000/tcp	X11	Access Denied	If accessible, could allow remote GUI control—CVE-1999-0526 (unauth access).
6667/tcp	IRC	UnrealIRCd	CVE-2010-2075—backdoor in version 3.2.8.1 (shipped with precompiled malware).
8009/tcp	AJP13	Apache JServ	CVE-2020-1938 (Ghostcat)—arbitrary file read and possible RCE on Tomcat.
8180/tcp	HTTP	Apache cat/Coyote 1.1	Tom- JSP CVE-2009-3548—unauthenticated admin access, default creds.